

Issue Specific Policy for Ransomware

Semir Hot, Harrison Maksimik

March 10, 2024

Contents

1	Statement of Policy	1
1.1	Purpose	1
1.2	Scope	1
1.3	Definitions	2
1.4	Responsibilities	2
2	Authorized Usage of Equipment	3
3	Systems Management	3
3.1	Management of stored materials	3
3.2	Monitoring	4
3.3	Virus protection	4
3.4	Encryption	4
4	Policy Compliance	5
4.1	Procedures for reporting violations	5
4.2	Penalties for violations	5
5	Scheduled Reviews	5

1 Statement of Policy

1.1 Purpose

The purpose of this policy is to protect the organization from ransomware attacks. Our organization has already been the target of a phishing attack, which could have resulted in significant damages to our information assets if a ransomware payload were deployed. It's critical to our business that

Confidentiality, Integrity and Availability be maintained in the organizations network and information assets. For this reason, a new policy specific to this issue is needed to regulate the access to information assets on the network, and to strengthen the security practices for network attached information assets. Ransomware attacks may also impact the integrity and confidentiality of our user's data, which we must prevent to avoid damage to both our user's privacy, and our reputation.

1.2 Scope

The scope of this policy pertains only to the issue of ransomware infections on assets owned by and incorporated by the organization. Organization personnel and information assets, as well as all other devices connected to the organization's network, should all be governed by this policy. The information assets taken into particular consideration include the automated gas pump systems, point of sale systems, surveillance system, inventory system, and network.

1.3 Definitions

- Ransomware: a type of malware in which files on a system are encrypted, locking a user out of their data until a ransom is paid.
- Full backup: copies all data on a system to an external storage media.
- Incremental backup: copies only the data that has changed since the previous backup to an external storage media.
- SIEM: security information and management, a system in which logs can be aggregated across many different systems, including off-premises systems.
- RBAC: role-based access control, an access control model in which users are assigned roles which contain certain permissions.
- IDS: intrusion detection system, a piece of software or hardware that monitors and alerts system administrators to potential intrusions into a system.
- NIDS: network intrusion detection system, an IDS which monitors an entire network.
- HIDS: host intrusion detection system, an IDS which monitors a single host in a network. Tripwire is an example of this type of software.

1.4 Responsibilities

The responsibilities to uphold this policy extend to all stakeholders of our organization. All users of information assets and systems in our organization must read, understand, agree to, and uphold the requirements of this policy. It should be the responsibility of the Chief Information Security Officer (CISO), along with other parties of interest, to develop and maintain this issue-specific security policy. It should be the responsibility of line managers to enforce compliance with this policy among other personnel. Contractors who have access to information assets and systems must be held to the same requirements as well. It is, however, our organization's own duty to ensure that the use of third-party services is in compliance with our security policies.

2 Authorized Usage of Equipment

It is critical to our business that users maintain the ability to access information assets. However, in order to maintain confidentiality and mitigate the spread of ransomware, a proper access control system must be created and maintained. In the short term, our organization should implement a RBAC model as described in another document.

3 Systems Management

3.1 Management of stored materials

Backups are the most reliable method of recovery from a ransomware attack. All systems which are connected to the internet should follow appropriate backup procedures based on the assessed damages of losing that system. The most critical systems should ensure that a regularly scheduled backup task is run in which several copies of data are made following the *3-2-1 backup rule*: three copies of data, in two different media, with one copy off-site. This task should ensure that local data backups are created daily, and off-site backups are created at least weekly. Less critical systems should still ensure that daily on-site backups, and weekly off-site backups are made as costs permit.

Our organization must also consider the costs associated with making a full backup of data. A full backup requires a large amount of bandwidth, storage space, and time. This task cannot be efficiently run on a daily basis. Thus, our organization should make use of a mixture of full and incremental backups. An effective approach that utilizes this system is the *grandfather-father-son* backup strategy. In this system, a full backup will

be made monthly, called the *grandfather* backup. Then, another full backup should be made weekly, called the *father* backup. An incremental backup should be made every day in which neither a *grandfather* nor *father* backup are made; this incremental backup is called the *son* backup. Generally, *grandfather* backups should be rotated yearly, *father* backups should be rotated quarterly, and *son* backups should be rotated monthly. The specific length of backup retention may be subject to change based on the criticality of a system, which should be defined in a system-specific security policy.

Logs are also important to maintain for forensic readiness. For critical assets, our organization will follow the NIST standard of a 3-year retention policy. Less critical logs can be retained for 1 year or less. For the purposes of ransomware detection and legal remediation, it will be important for our organization to keep adequate logs of system events, intrusion detection system logs, network connections, and email logs. All logs should be managed using an off-premises SIEM.

3.2 Monitoring

Intrusion detection systems (IDS) can be used to monitor the organization's network for security breaches or policy violations. In particular, a network-based intrusion detection system (NIDS) should be used to aggregate and monitor all network traffic on the organization's network, and host-based intrusion detection systems (HIDS) should be used for individual, critical devices on the network to detect internal threats. System-specific policies should mandate the use of HIDS when appropriate. A qualified administrator should have access to the aggregated data and be ready to respond to alerts.

3.3 Virus protection

Virus protection software is an important line of defense for preventing ransomware infections. Each system that connects to the organization's network should have an adequate antivirus system installed. On Windows machines, it is recommended that the antivirus solution provides active protection - that is, the program should run in the background at all times and monitor/prevent suspicious activity. Server systems running other operating systems, such as GNU/Linux or a BSD derivative, should also have an antivirus installed, though this need not be an active antivirus. The frequency and conditions in which an antivirus program should be run on server systems should be defined by system-specific policies. A reliable choice of antivirus for these server systems is ClamAV.

3.4 Encryption

Encryption is another aspect of data security that must be considered when developing a ransomware protection policy. The primary concern is the potential for an attacker to siphon data from our information assets before being encrypted by the ransomware. In order to prevent this breach of confidentiality, our organization must implement an adequate policy for encrypting stored data. It's important for the encryption algorithms used to be well-tested and effective in the modern day, as new technology continuously makes older encryption algorithms obsolete.

4 Policy Compliance

4.1 Procedures for reporting violations

Should any employee witness a violation of this security policy, their line manager should be informed as soon as possible with adequate details describing the perceived violation of policy. If an employee feels uncomfortable reporting the issue to a line manager, or if a contractor or third-party worker wishes to report a security policy violation, an email can be sent to the security department containing all necessary information.

4.2 Penalties for violations

Additional training should be mandatory for any employee found to be in accidental violation of this policy. Additionally, our organization must review and update all training procedures as necessary after such an incident. Intentional circumvention of this policy, including the intentional and malicious introduction of ransomware into our organization's information systems, could be grounds for termination of employment.

5 Scheduled Reviews

This policy should be reviewed by the CISO and other parties of interest on an annual basis. New technologies may make the current security controls obsolete in the future; each of the provided guidelines under the *Systems Management* section should be carefully reviewed during this time. Upon updates being made to this issue-specific policy, any relevant system-specific policies should also be immediately reviewed and updated.